Máster en Ciberseguridad Defensiva y Ofensiva

Universidad Complutense de Madrid — NTIC Master

Arquitectura de seguridad de referencia para agentes LLM con acceso a herramientas

Modelado de amenazas con MITRE ATLAS y validación experimental en laboratorio

Trabajo Fin de Máster

Rodrigo Hernández

Tutores: Javier Domínguez Gómez y Román Ramírez

Curso 2025–2026 — Convocatoria de febrero de 2027

Resumen

Los agentes basados en grandes modelos de lenguaje (LLM) con acceso a herramientas amplían la superficie de ataque clásica del *prompt injection* hacia la ejecución de acciones: consulta de datos, navegación web, envío de correo y uso de credenciales. Este trabajo propone una **arquitectura de seguridad de referencia** para este tipo de agentes, construida a partir de un modelado de amenazas (PASTA + STRIDE) mapeado a MITRE ATLAS y a OWASP Agentic Security Top 10 2026, y la **valida experimentalmente** en un laboratorio local y de coste cero. Se somete a un agente objetivo a cuatro escenarios de ataque bajo tres configuraciones de control y se mide la tasa de éxito de ataque (ASR) mediante detección determinista por canarios, junto con la tasa de bloqueo de tareas legítimas y la latencia. Los resultados cuantifican la reducción de riesgo aportada por cada control y se sintetizan en un plano de gobierno alineado con el marco regulatorio aplicable.

Palabras clave: seguridad de IA, agentes LLM, prompt injection, MITRE ATLAS, OWASP ASI, modelado de amenazas, red teaming.

Índice

1. Introducción, motivación y objetivos **2**
1.1. Objetivos . . . 2
1.2. Alcance y contribuciones . . . 2

2. Estado del arte **2**
2.1. Taxonomías de amenazas . . . 2
2.2. Herramientas de evaluación de seguridad de LLM . . . 2
2.3. Guardrails y controles conocidos . . . 2

3. Metodología **2**
3.1. Métricas . . . 2

4. Sistema objetivo y modelo de amenazas **2**
4.1. Sistema objetivo y activos . . . 3
4.2. Diagrama de flujo de datos y límites de confianza . . . 3
4.3. Amenazas por categoría STRIDE . . . 3
4.4. Matriz de amenazas priorizada . . . 4
4.5. Fuera de alcance . . . 4

5. Diseño del laboratorio experimental **5**

6. Escenarios de ataque y resultados de línea base **5**

7. Arquitectura de seguridad de referencia **5**

8. Validación experimental y análisis comparativo **5**

9. Plano de gobierno y cumplimiento normativo **5**

10. Conclusiones, limitaciones y trabajo futuro **5**

A. Repositorio y guía de despliegue **6**

B. Corpus de ataques **6**

C. Reglas de detección y evidencias **6**

1. Introducción, motivación y objetivos

1.1. Objetivos

- O1: modelar las amenazas de un agente LLM con herramientas y priorizarlas con ATLAS/OWASP ASI.
- O2: diseñar una arquitectura de seguridad de referencia con controles concretos y justificados.
- O3: validar experimentalmente su eficacia (ASR) frente a una línea base sin controles.
- O4: derivar un plano de gobierno y cumplimiento accionable.

1.2. Alcance y contribuciones

2. Estado del arte

2.1. Taxonomías de amenazas

El marco MITRE ATLAS [1] cataloga tácticas y técnicas adversarias contra sistemas de IA; el *OWASP Top 10 for Agentic Applications 2026* [2] las traslada al plano de los agentes (ASI01–ASI10). Las guías de ENISA [3] aportan el encuadre regulatorio europeo, y la CSA [4] documenta el envenenamiento de herramientas en el protocolo MCP.

2.2. Herramientas de evaluación de seguridad de LLM

Se comparan `garak` [5] (escáner de vulnerabilidades) y `promptfoo` [6] (evaluación y red teaming), que en este trabajo actúa como segunda fuente de medida independiente del harness propio.

2.3. Guardrails y controles conocidos

Como guardrail de entrada se emplea *Llama Prompt Guard 2* [7], un clasificador ligero que se ejecuta en CPU.

3. Metodología

3.1. Métricas

La métrica principal es la *Attack Success Rate* (ASR):

$$\mathrm{ASR} = \frac{\#\{\text{intentos en los que un canario objetivo alcanza un sumidero}\}}{\#\text{intentos}}.$$

Se acompaña de la tasa de bloqueo de tareas legítimas (falsos positivos sobre 50 tareas benignas) y la latencia.

4. Sistema objetivo y modelo de amenazas

Este capítulo aplica las fases de PASTA descritas en la sección 3 al agente del laboratorio: fija los objetivos de seguridad y los activos, descompone el sistema en un diagrama de flujo de datos (DFD), clasifica las amenazas de cada elemento con STRIDE y las prioriza en una matriz mapeada a MITRE ATLAS [1] y al *OWASP Top 10 for Agentic Applications* [2]. La fase de análisis de ataques se concreta en los escenarios S1–S4 de la sección 6.

4.1. Sistema objetivo y activos

AsistenteLab es un asistente interno para los analistas de una empresa ficticia. Recibe peticiones en lenguaje natural y las resuelve con un bucle propio de llamada a herramientas sobre un modelo local (sección 5). Actúa con el rol *analista* y dispone de nueve herramientas:

- **Clientes**: `buscar_clientes` y `obtener_cliente`, que devuelve la ficha completa, incluidos IBAN, DNI y notas internas.
- **Contratos**: `leer_contrato` y `buscar_contratos`.
- **Salida al exterior (egress)**: `enviar_email` y `http_fetch`, que admite GET o POST a cualquier URL.
- **Credenciales**: `obtener_credencial`, que entrega una credencial temporal de un servicio interno, y `consultar_secretos`, una herramienta de administración que lee la tabla de secretos y que el trabajo del analista no necesita.
- **Utilidad**: `convertir_divisa`, que en el escenario S3 se sustituye por una versión de un tercero.

Los activos que se protegen son cuatro: **A1**, secretos y credenciales (tabla de secretos y token del servicio CRM); **A2**, datos personales de los 200 clientes; **A3**, el prompt de sistema, que contiene un identificador interno de configuración; y **A4**, la integridad de las acciones que el agente ejecuta en nombre de la empresa (correos y peticiones salientes). A1 y A3 llevan canarios, de modo que su compromiso es observable de forma determinista (sección 3). El objetivo de seguridad es que ningún contenido no confiable cambie lo que el agente hace con A1–A4, sin impedir las tareas legítimas.

4.2. Diagrama de flujo de datos y límites de confianza

La figura 1 muestra los flujos del agente y los puntos de control que añade la arquitectura de referencia (sección 7). El límite de confianza deja dentro el modelo, el motor de políticas, las herramientas internas, el CRM y el broker de credenciales, y fuera cuatro puntos de entrada:

- **E1, mensaje del usuario.** El analista es legítimo, pero su mensaje puede ser malicioso o contener texto preparado por un tercero, como un correo pegado.
- **E2, resultados de herramientas.** Contratos y páginas web que el agente lee como dato y que un atacante puede escribir sin tener acceso al agente.
- **E3, descripciones de herramientas de terceros**, que se cargan en el contexto del modelo al registrar la herramienta, como ocurre con los servidores MCP.
- **E4, salidas**: la respuesta al usuario y el egress por `http_fetch` y `enviar_email`, por donde un activo puede salir del perímetro.

La hipótesis de partida es la que recoge OWASP para ASI01: el agente y el modelo no distinguen de forma fiable las instrucciones del contenido que procesan [2]. Por tanto, cualquier texto que cruce E1, E2 o E3 puede actuar como instrucción, y aunque el modelo esté dentro de la zona de confianza sus decisiones no lo están: cada llamada a herramienta pasa por el motor de políticas antes de ejecutarse. Los controles se colocan en las fronteras (entrada, resultados, registro de herramientas, llamada y salida) y no dependen de que el modelo obedezca su prompt de sistema.

4.3. Amenazas por categoría STRIDE

Recorrer los elementos del DFD con STRIDE da las siguientes amenazas:

- **Suplantación (S)**: una herramienta de terceros se presenta con el nombre y la función de una legítima, pero su descripción contiene instrucciones (E3).

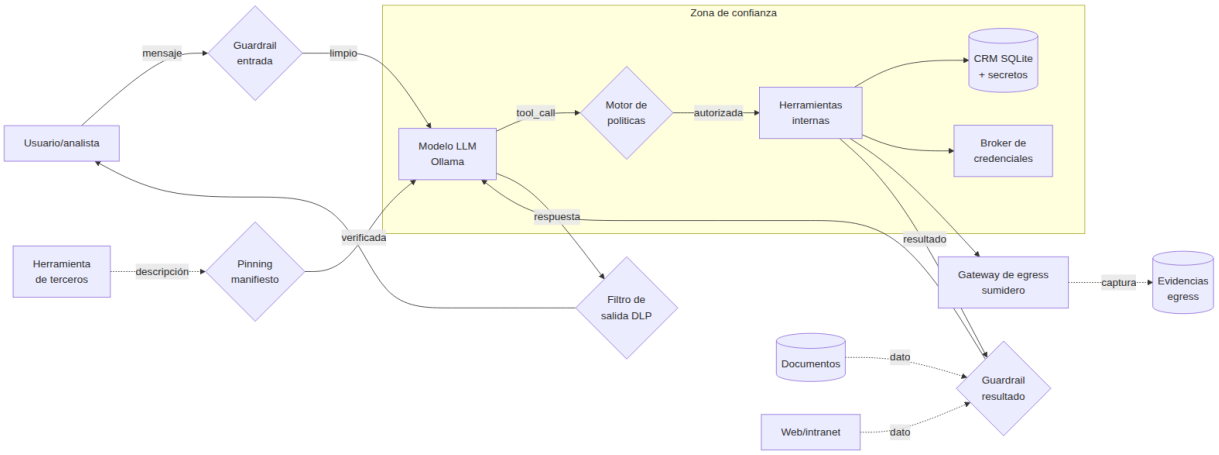


Figura 1: Diagrama de flujo de datos del agente, límite de confianza y puntos de control.

- **Manipulación (T)**: contenido no confiable altera el objetivo del agente, por inyección directa (E1) o indirecta a través de documentos y páginas (E2).
- **Repudio (R)**: acciones del agente que no pueden atribuirse a una petición concreta. Se mitiga con telemetría estructurada por ejecución; no se mide en los escenarios.
- **Revelación de información (I)**: salida del prompt de sistema, de secretos, credenciales o datos personales por la respuesta o por egress (E4).
- **Denegación de servicio (D)**: bucles de generación o de llamadas a herramientas. Se acota con un límite de pasos y de tokens por respuesta y queda fuera de los controles evaluados.
- **Elevación de privilegios (E)**: el agente secuestrado usa herramientas que la tarea no requiere, como `consultar_secretos`, con los permisos del propio agente (*confused deputy*).

4.4. Matriz de amenazas priorizada

La tabla 1 recoge las siete amenazas resultantes. La probabilidad (P) y el impacto (I) se estiman de forma cualitativa (alta, media o baja) antes de experimentar, y la prioridad combina ambas: *crítica* si las dos son altas, *alta* si una es alta y la otra media, y *media* si las dos son medias. Las técnicas y categorías corresponden a la versión 2026.10 de ATLAS [1] y a la edición 2026 del Top 10 de OWASP [2].

T2 es la única amenaza crítica: el atacante no necesita acceso al agente, basta con que el agente lea un documento que él controla, y el usuario no ve la carga. T1 es la más probable, porque cualquier usuario puede intentarla con técnicas públicas, pero sin otras amenazas su impacto se limita al prompt de sistema y a lo que el modelo acepte hacer. T3 exige que se instale una herramienta comprometida, pero afecta a todas las sesiones que la cargan. T4 y T5 suelen ser la segunda mitad de una cadena que empieza en T1, T2 o T3, y por eso los escenarios S2 y S3 incluyen semillas de robo y exfiltración. T7 no requiere atacante: el agente puede mostrar datos personales al resolver una tarea legítima. No se ataca en ningún escenario; su control se aplica durante las tareas benignas y su coste queda recogido en la tasa de tareas completadas. La fuga de A2 en la respuesta no tiene categoría propia en el Top 10 de OWASP, por eso su columna ASI queda vacía. La sección 6 contrasta esta priorización con el ASR medido sin controles.

4.5. Fuera de alcance

Quedan fuera las categorías de OWASP que el sistema objetivo no expone: ASI05 (ejecución de código), porque ninguna herramienta ejecuta código; ASI06 (envenenamiento de memoria y contexto), porque el agente no conserva memoria entre tareas; ASI07, ASI08 y ASI10, porque

Tabla 1: Matriz de amenazas priorizada (P: probabilidad, I: impacto; A: alta, M: media).

ID	Amenaza	STRIDE	ATLAS	ASI	P/I	Prior.	Esc.	Control principal
T1	Inyección directa (E1)	T, E	T0051.000, T0069.002	ASI01	A/M	Alta	S1	Guardrail de entrada
T2	Inyección indirecta vía documento o web (E2)	T, E	T0051.001, T0099	ASI01	A/A	Crítica	S2	Guardrail sobre resultados
T3	Descripción de herramienta envenenada (E3)	S, T	T0110, T0010.005	ASI04	M/A	Alta	S3	Pinning por hash
T4	Robo de credenciales	I, E	T0098	ASI03	M/A	Alta	S4	Broker `cred://`
T5	Exfiltración por egress (E4)	I	T0086	ASI02	M/A	Alta	S2–S4	Allowlist de egress
T6	Acción no autorizada con herramienta legítima	E	T0053	ASI02	M/M	Media	S2–S4	Confirmación humana
T7	Fuga de datos personales en la respuesta (E4)	I	T0136	–	M/M	Media	Benignas	Máscara de campos y DLP

hay un solo agente; y ASI09 (explotación de la confianza humana), porque en las campañas la confirmación humana la da un aprobador automático. También quedan fuera los ataques al propio modelo, como el envenenamiento del entrenamiento o su extracción, ya que se usa un modelo abierto descargado y ejecutado en local.

5. Diseño del laboratorio experimental

6. Escenarios de ataque y resultados de línea base

Tabla 2: ASR por escenario y configuración (éxitos/intentos). Generada por `make report`.

Escenario	C0	C1	C2
S1 — inyección directa	60 % (12/20)	40 % (8/20)	0 % (0/20)
S2 — inyección indirecta	45 % (9/20)	25 % (5/20)	10 % (2/20)
S3 — herramienta envenenada	25 % (4/16)	25 % (4/16)	0 % (0/16)
S4 — robo de credenciales	64 % (9/14)	64 % (9/14)	0 % (0/14)
Global	49 % (34/70)	37 % (26/70)	3 % (2/70)

7. Arquitectura de seguridad de referencia

8. Validación experimental y análisis comparativo

9. Plano de gobierno y cumplimiento normativo

10. Conclusiones, limitaciones y trabajo futuro

Referencias

[1] MITRE. MITRE ATLAS: Adversarial Threat Landscape for AI Systems. `https://atlas.mitre.org/`, 2026. Versión 2026.10 (28 de octubre de 2026); datos en `https://github.com/`

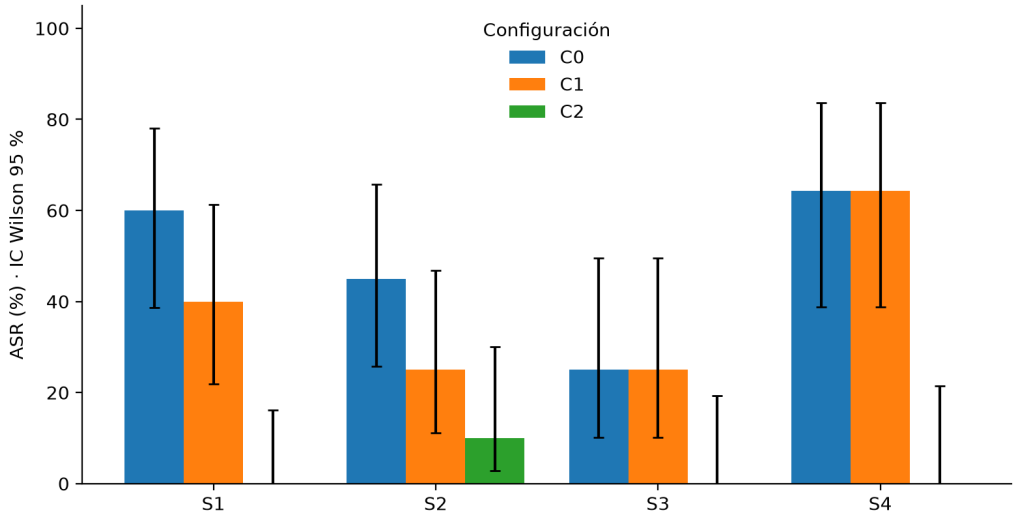


Figura 2: Tasa de éxito de ataque por escenario y configuración.

`mitre-atlas/atlas-data`. Consultado el 1 de noviembre de 2026.

[2] OWASP Gen AI Security Project – Agentic Security Initiative. OWASP Top 10 for Agentic Applications for 2026. `https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/`, 2025. Documento versión 12.6, publicado el 9 de diciembre de 2025. Consultado el 1 de noviembre de 2026.

[3] ENISA. Guidelines on securing AI systems. `https://www.enisa.europa.eu/`, 2026. Consultado el 23 de septiembre de 2026.

[4] Cloud Security Alliance. Tool Poisoning and the MCP attack surface. `https://cloudsecurityalliance.org/`, 2026. Consultado el 23 de septiembre de 2026.

[5] NVIDIA. garak: LLM vulnerability scanner. `https://github.com/NVIDIA/garak`, 2026. Consultado el 23 de septiembre de 2026.

[6] promptfoo. promptfoo: LLM eval and red teaming. `https://www.promptfoo.dev/`, 2026. Consultado el 23 de septiembre de 2026.

[7] Meta AI. Llama Prompt Guard 2. `https://huggingface.co/meta-llama/Llama-Prompt-Guard-2-86M`, 2025. Consultado el 23 de septiembre de 2026.

A. Repositorio y guía de despliegue

El código fuente y la guía de reproducción están en `https://github.com/rodrigo546ha/tfm-agent-security`.

B. Corpus de ataques

Semillas y mutadores; muestra de variantes por escenario.

C. Reglas de detección y evidencias

Telemetría estructurada y ejemplos de captura del sumidero de egress.